SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Code of Conduct:

I D K Sumalatha(192424023) Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

D k Sumalatha

Social Engineering Simulation

1. AIM AND SCOPE

Aim: To understand how publicly available information can expose an organization to reconnaissance and social engineering risks, to conduct a controlled phishing-awareness exercise using dummy accounts, and to interpret service information from an authorized Nmap scan.

Course Outcome (CO2): Execute footprinting in social engineering, including DNS analysis, competitive intelligence gathering, and attack simulations, to identify potential security risks.

Scope and Safety

- Use theHarvester to collect publicly indexed information for the assigned domain and record only the results actually returned by the tool.
- Run the GoPhish campaign only against the dummy employee accounts provided in the lab. Do not collect real passwords or sensitive personal information.
- Scan scanme.nmap.org only within the target's permitted use and the lab instructions. Avoid denial-of-service testing or intrusive follow-up activity.
- Use the findings to explain defensive improvements, not to target real employees.

2. EXPERIMENT 1: OSINT EMAIL ENUMERATION USING THEHARVESTER

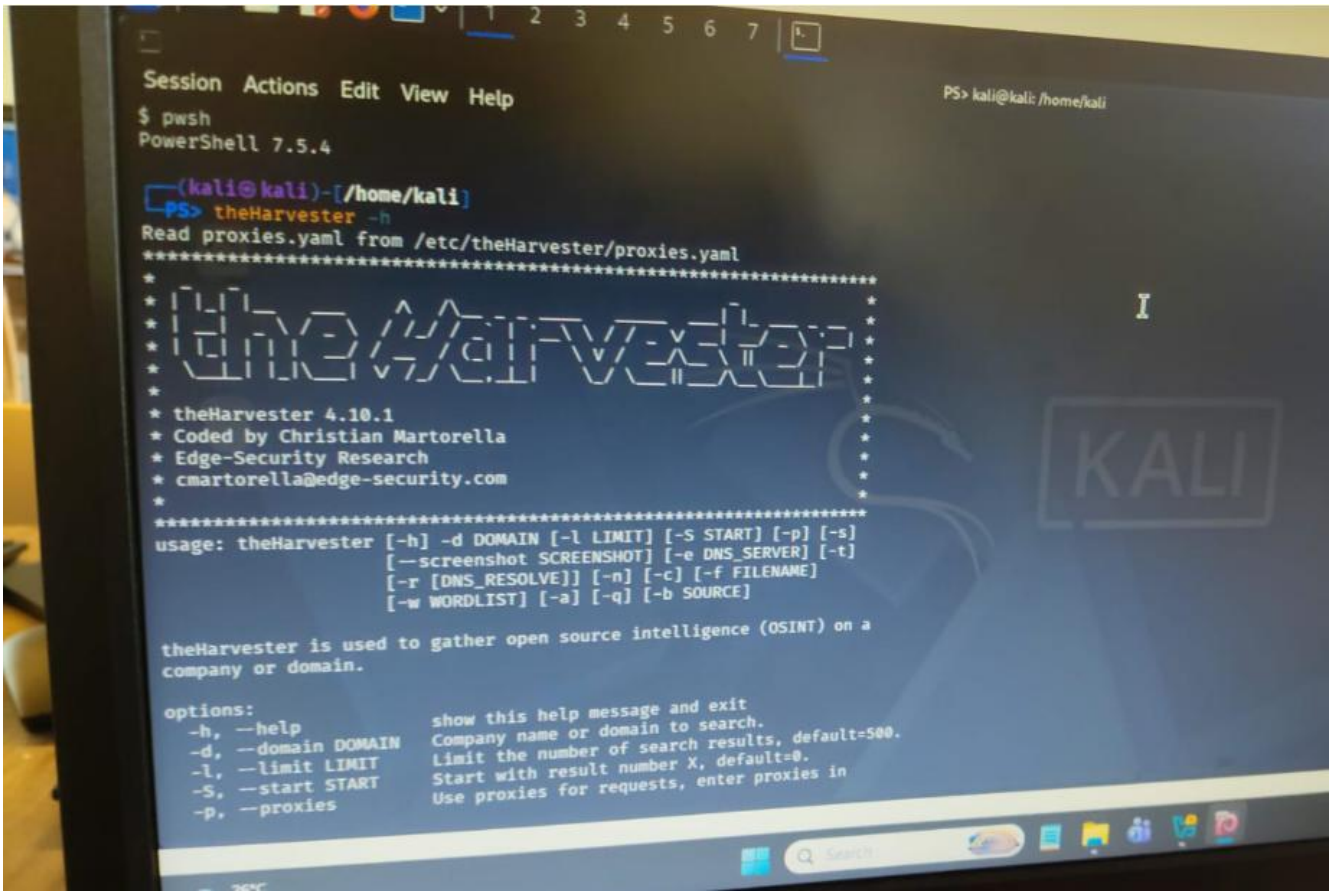
2.1 Aim

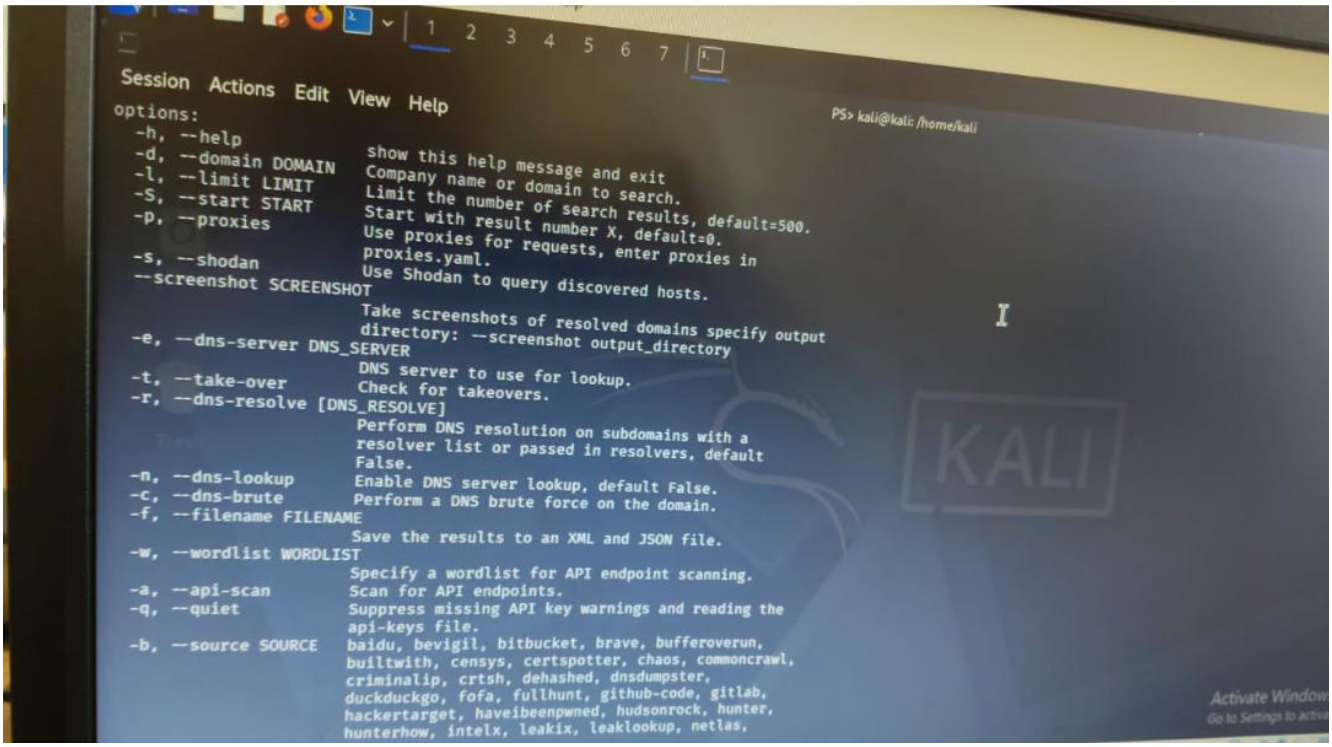
To use theHarvester in Kali Linux to identify publicly available email addresses, subdomains, hosts, and IP addresses associated with tesla.com, and assess how this information may create social engineering risks.

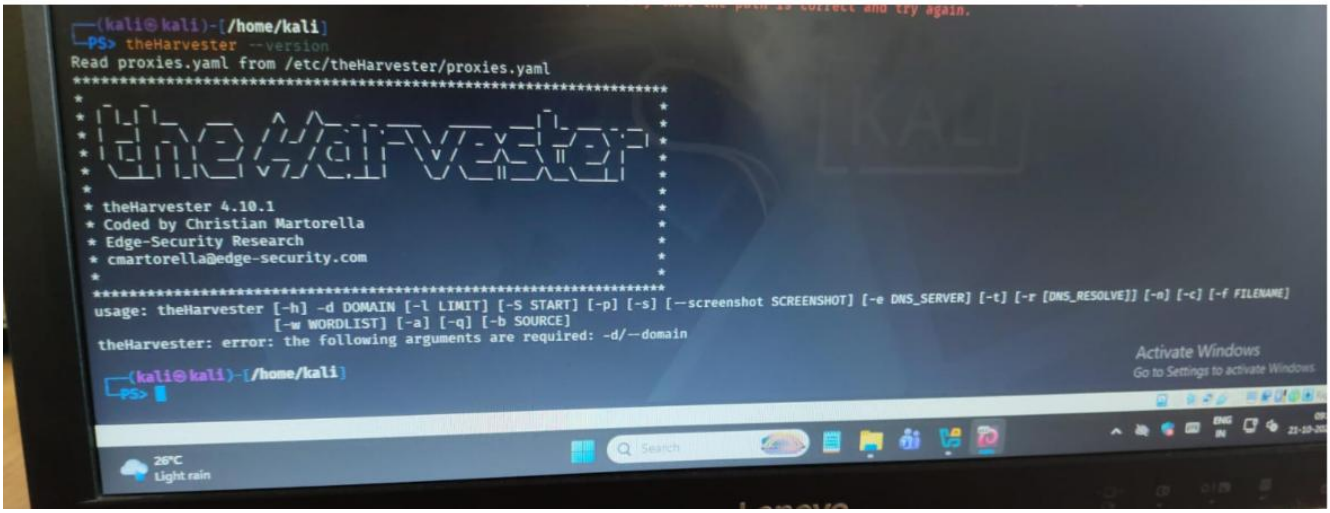
2.2 Tool and Environment

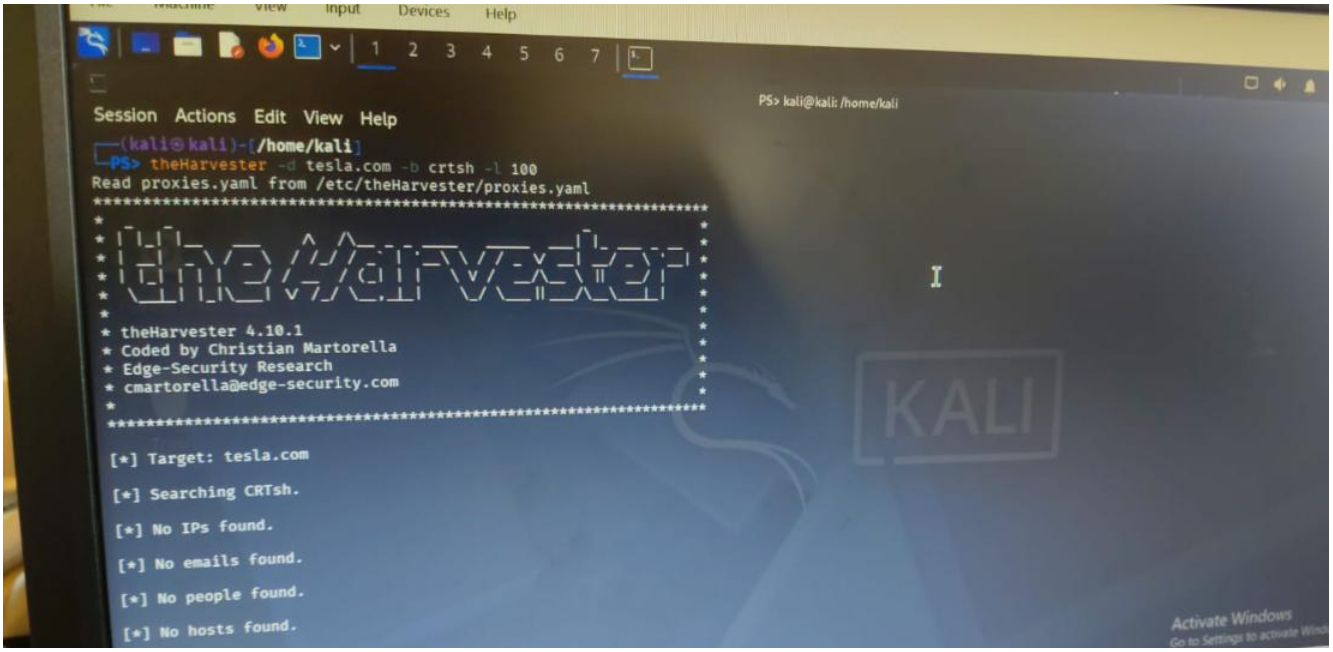
- Operating System: Kali Linux
- Tool: theHarvester
- Target domain: tesla.com
- Purpose: Authorized academic OSINT assessment using publicly available sources.

2.3 Commands Executed









2.4 Procedure

1. Open Kali Linux and launch a terminal.
2. Check theHarvester availability and review its help output.
3. Run the selected source against tesla.com.
4. Record the discovered email addresses, subdomains, hosts, and IP addresses exactly as displayed.
5. Capture screenshots showing the command and the resulting output.
6. Group email addresses by likely function only when the address or public context supports that classification; otherwise label the role as Unknown/Unconfirmed.

2.5 Findings Table

Finding type	Actual result	Source/tool output	Notes

Email addresses	[Paste actual count/list or summarize]	[Source returned by tool]	[Do not guess]
Subdomains	[Paste actual count/list]	[Source returned by tool]	[Verify relevance]
Hosts	[Paste actual hostnames]	[Source returned by tool]	[Record only observed data]
IP addresses	[Paste actual IPs]	[Source returned by tool]	[Do not assume ownership without verification]

2.6 Reconnaissance and Risk Analysis

Public email patterns and infrastructure information can help an attacker understand an organization's naming conventions, identify likely departments, and create believable pretexts. The existence of an address does not prove that it is active or that the named person works in a particular role.

- Spear-phishing risk: A message can be tailored to a department's expected work, such as a fake support ticket or recruitment notice.
- Credential-harvesting risk: A deceptive message may try to direct a recipient to a fraudulent sign-in page. In this assessment, describe the risk only; do not build or deploy a page that collects real credentials.
- Impersonation risk: Public naming conventions and technical terminology can be copied to make a sender or request appear legitimate.
- Infrastructure mapping risk: Subdomains, hosts, and IP addresses may reveal exposed services or technology relationships, but each result requires validation and may be outdated.

2.7 Countermeasures

7. Publish only necessary contact information and review public pages, repositories, documents, and metadata regularly.
8. Deploy and monitor SPF, DKIM, and DMARC to make domain spoofing harder.
9. Use phishing-resistant multifactor authentication where possible.
10. Train employees to verify unusual requests through a separate trusted channel.
11. Provide a simple phishing-reporting button or mailbox and acknowledge reports promptly.
12. Use secure email filtering, URL reputation checks, attachment sandboxing, and domain-impersonation monitoring.

13. Apply least privilege and separate public contact mailboxes from privileged accounts.
14. Monitor exposed assets and remove obsolete DNS records and public test systems.

2.8 Result

The OSINT assessment was [completed / partially completed]. Actual findings: [insert concise summary from your terminal output]. The main risks identified were [insert evidence-based risks].

3. EXPERIMENT 2: PHISHING AWARENESS SIMULATION USING GOPHISH

3.1 Aim

To conduct a controlled phishing-awareness simulation against dummy employee accounts, measure delivery, opens, and clicks, and recommend improvements based on the observed results.

3.2 Safety Requirements

- Use only the lab-provided dummy accounts and approved mail server settings.
- Use a clearly controlled training scenario and do not impersonate an unrelated real organization.
- Do not collect passwords, MFA codes, or other secrets. A click-only landing page or training page is sufficient.
- Do not send the campaign to public addresses or real employees without explicit written authorization.

3.3 Campaign Setup and Procedure

15. Start GoPhish using the lab's approved installation and startup instructions.
16. Sign in with the credentials supplied by the instructor or lab administrator. Do not guess or bypass unknown credentials.
17. Create a sending profile using the lab-approved SMTP server and sender identity.
18. Create a training email template with a clear awareness objective and a harmless link to the lab training page.
19. Create a recipient group containing only the supplied dummy accounts.
20. Create and launch the campaign according to the instructor's directions.
21. Monitor the campaign dashboard and record delivered, opened, and clicked counts.
22. Export or screenshot the campaign results and include them in this report.

3.4 Safe Example Email Template

Subject: Security Awareness Exercise — Please Review

HelloTeam,

This is a controlled security-awareness exercise. Please open the training link provided by your lab instructor to review the signs of suspicious email messages.

Do not enter a password or other sensitive information. If you are unsure about an email, verify the request through a trusted channel and report it to the IT/security team.

Thank you,
Security Awareness Team

Use the approved lab training URL in GoPhish. Do not replace it with a real login page or a page that captures credentials.

3.5 Metrics and Calculations

Use the campaign dashboard's actual counts. State whether rates use delivered emails or total recipients as the denominator; for consistency, the formulas below use delivered emails.

Delivery rate (%) = (Emails delivered ÷ Emails attempted) × 100

Open rate (%) = (Unique recipients who opened ÷ Emails delivered) × 100

Click rate (%) = (Unique recipients who clicked ÷ Emails delivered) × 100

Metric	Actual count	Rate / result
Emails attempted	[Enter count]	—
Emails delivered	[Enter count]	[Calculate delivery rate]
Unique opens	[Enter count]	[Calculate open rate]
Unique clicks	[Enter count]	[Calculate click rate]

3.6 Interpretation

Delivery rate indicates whether the lab mail system delivered the messages. Open rate is an imperfect measure because mail clients may block or automatically load tracking content. Click rate indicates interaction with the link, but does not by itself prove that a user entered information. Because this exercise should not collect credentials, no credential-submission metric is required.

Observed result: [Summarize actual delivery, open, and click rates]. Explain what the results suggest about awareness, while noting the small sample size and limitations.

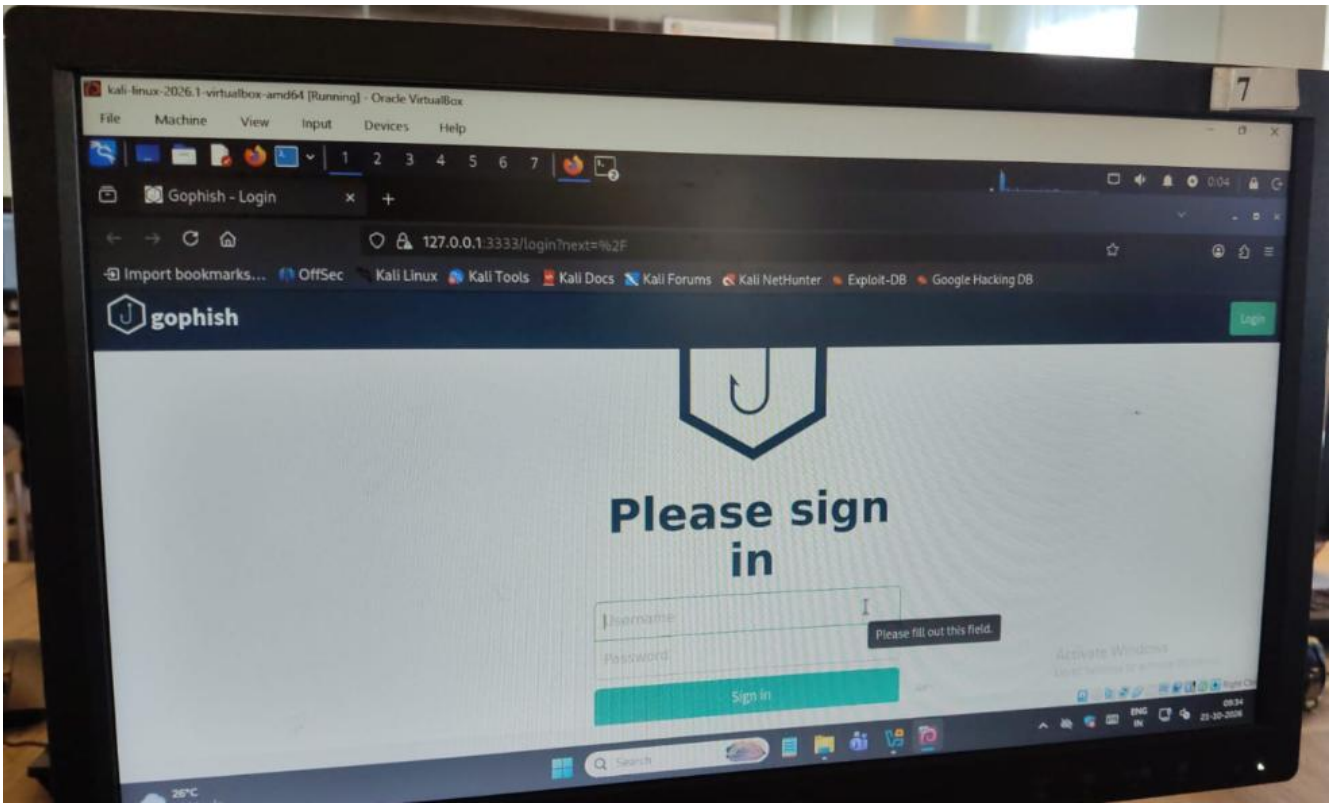
3.7 Recommendations

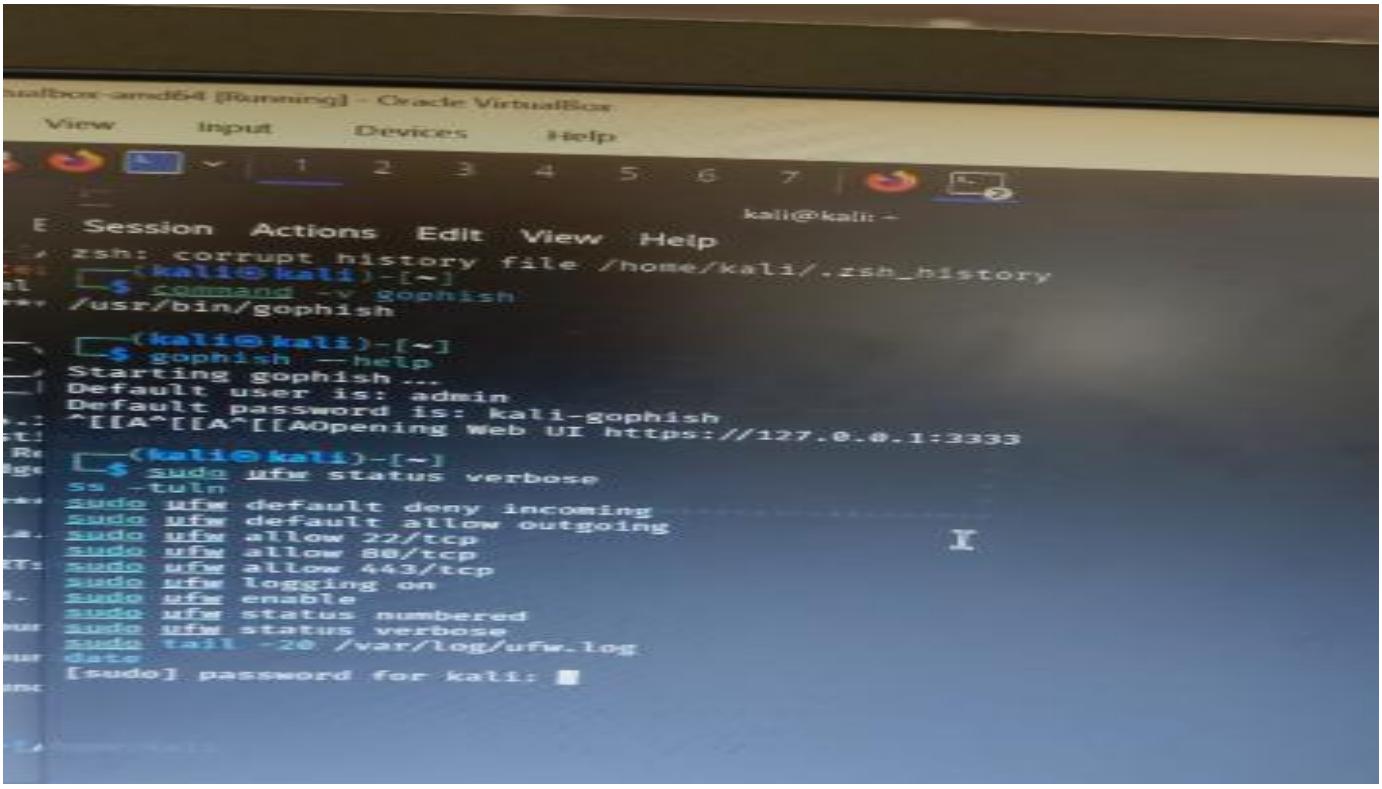
23. Run short, regular awareness sessions with examples of suspicious sender addresses, urgent language, unexpected attachments, and mismatched links.
24. Teach staff to navigate to known sites directly rather than using unexpected email links.

25. Provide an easy method to report suspicious messages and recognize employees who report them.
26. Repeat simulations using varied, safe scenarios and compare trends over time rather than judging individuals from one test.
27. Use multifactor authentication, email authentication, and secure email filtering as technical controls.
28. Share results in aggregate and use them for coaching, not public shaming.

3.8 Result

The GoPhish awareness campaign was [completed / partially completed] using [number] dummy accounts. Actual delivery rate: [__%]; open rate: [__%]; click rate: [__%]. The key improvement areas are [insert based on actual results].




View Input Devices Help
kali@kali: ~
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
/usr/bin/gophish
gophish --help
Starting gophish ...
Default user is: admin
Default password is: kali-gophish
^[[A^[[A^[[AOpening Web UI https://127.0.0.1:3333
sudo ufw status verbose
ss -tuln
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 22/tcp
sudo ufw allow 80/tcp
sudo ufw allow 443/tcp
sudo ufw logging on
sudo ufw enable
sudo ufw status numbered
sudo ufw status verbose
sudo tail -20 /var/log/ufw.log
[sudo] password for kali:

4. EXPERIMENT 3: NMAP AGGRESSIVE SCAN ON scanme.nmap.org

4.1 Aim

To use Nmap's aggressive scan option on the designated scanme.nmap.org host to observe open ports, service versions, OS-detection information where available, and potential social engineering risks.

4.2 Command Executed

nmap -A scanme.nmap.org

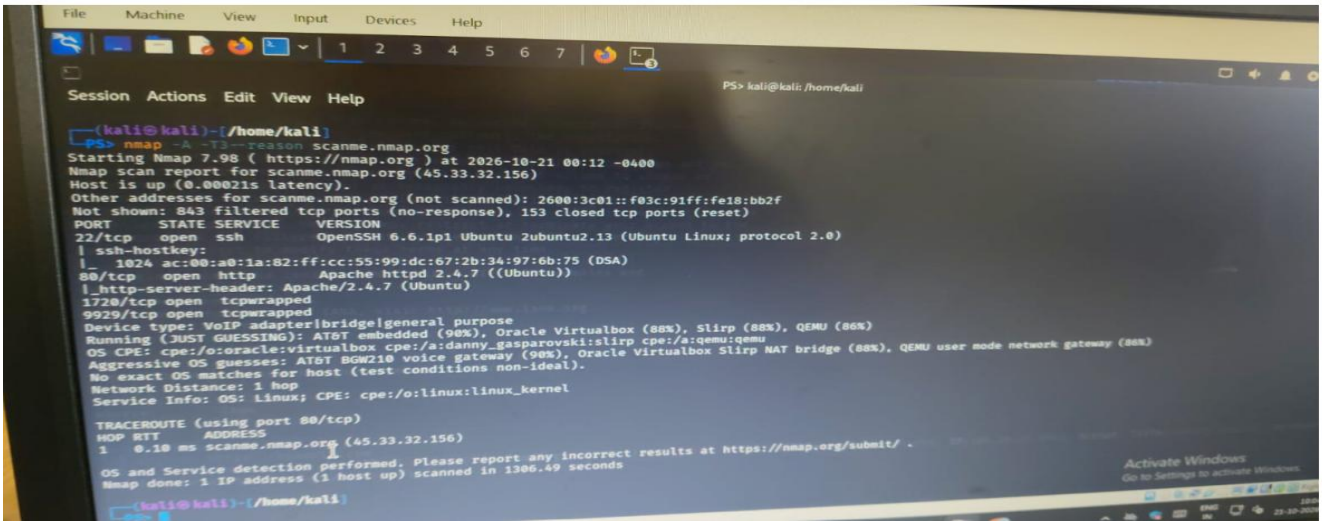
The -A option enables several detection features, including OS detection, version detection, script scanning, and traceroute. Results depend on network conditions, permissions, and what the target exposes. Follow the target's published scanning policy and your instructor's directions.

4.3 Procedure

29. Open a Kali Linux terminal.
30. Run the assigned command against scanme.nmap.org.
31. Wait for the scan to finish and record the scan date/time.
32. Record only the ports, services, versions, and OS guesses shown by your actual output.
33. Capture a screenshot of the command and results.

4.4 Output





4.5 Social Engineering Risk Scenario

An attacker could use service names and version information to make a technical support request sound credible. For example, they might claim to be investigating a service issue and ask an employee to run an unapproved command or share a configuration file. The scan output does not identify individual employees or prove that a vulnerability exists.

4.6 Defensive Recommendations

34. Keep internet-facing services to the minimum required and restrict management interfaces to trusted networks or VPN.
35. Patch supported services and remove obsolete software; verify exposure through authorized vulnerability management.
36. Use host firewalls, network segmentation, and monitoring for unexpected connection attempts.
37. Require IT support staff to verify identity and ticket context before changing settings or sharing information.
38. Never ask users to disclose passwords, MFA codes, private keys, or sensitive configuration through email or chat.
39. Use approved support tools and signed scripts; prohibit running commands supplied by an unverified caller.
40. Repeat scans only within approved scope and document the date, source, and limitations of the results.

4.7 Result

The Nmap scan was [completed / partially completed]. Observed open ports and services: [summarize actual output]. The main defensive priorities are [based on verified findings].

5. OVERALL RISK ANALYSIS

Risk	Likelihood	Potential impact	Suggested priority
Publicly exposed contact and infrastructure information	[Low/Medium/High, justify]	More convincing reconnaissance and impersonation	[Low/Medium/High]
Employees clicking deceptive links	[Based on campaign results]	Malware exposure or redirection to fraudulent sites	[Low/Medium/High]
Overexposed or outdated network services	[Based on scan evidence]	Increased attack surface	[Low/Medium/High]
Weak identity verification in support requests	[Assessment]	Unauthorized disclosure or configuration changes	[Low/Medium/High]

Risk ratings should be justified using evidence from the actual tool output, the lab campaign, and the organization's context. Do not label a service vulnerable solely because it is open.

6. SECURITY RECOMMENDATIONS

41. Reduce unnecessary public information and review exposed assets periodically.
42. Configure SPF, DKIM, and DMARC and monitor domain impersonation.
43. Use phishing-resistant MFA and least-privilege access.
44. Provide ongoing phishing-awareness training and an easy reporting process.
45. Verify support requests using a trusted, separate communication channel.
46. Patch and harden exposed services; restrict access to administrative interfaces.
47. Log and review email, endpoint, DNS, and network events to support timely detection and response.

7. CONCLUSION

This assessment demonstrates how OSINT, controlled phishing-awareness exercises, and service discovery can help identify security risks. Public information may support reconnaissance, while deceptive email and weak verification processes can increase the chance of social engineering success. Actual findings must be documented from the lab outputs. Reducing unnecessary exposure,

strengthening authentication, training users, and maintaining secure network services can reduce these risks.